

Security Assessment Report

Target	http://juice-shop:3000
Scan ID	eaae0d342f24445295dbb4aa098e1054
Generated	2026-10-07T14:30:03+00:00
Authorization	Confirmed by Demo operator at 2026-10-07T14:24:29+00:00
Scope notes	Full baseline of the local Juice Shop demo, including web server checks.

Automated, detection-only assessment. Findings come from open-source scanners and have not been manually verified or exploited; expect false positives and missed issues. This is not a substitute for a manual penetration test.

Summary

Critical	High	Medium	Low	Info
0	0	5	13	15

The security posture of the system is concerning with multiple medium severity issues identified. The most critical issues include missing anti-clickjacking headers, content security policy, and session ID in URL. These should be addressed immediately to mitigate potential risks.

Plan and tool runs

nmap: Initial port and service discovery

zap: Comprehensive web application baseline scan

nuclei: Template checks for common misconfigurations and technologies

nikto: Web server checks for additional security misconfigurations

Tool	Status	Duration	Findings	Raw output
nmap	ok	11.4s	1	nmap.xml
zap	ok	56.6s	9	zap.json
nuclei	ok	131.3s	13	nuclei.jsonl
nikto	timeout	123.3s	10	nikto.json

Findings

[Medium] Prometheus Metrics - Detect

NUCLEI-prometheus-metrics · nuclei · CVSS 5.3 · CVSS score 5.3 reported by nuclei · CWE-200

Where: http://juice-shop:3000/metrics (1 instance(s))

Prometheus metrics page was detected.

Evidence (from nuclei): Template matched at http://juice-shop:3000/metrics

Remediation guidance (AI-written): Disable or secure the Prometheus metrics endpoint to prevent unauthorized access.

[Medium] Missing Anti-clickjacking Header

ZAP-10020-1 · zap · zap rated it 'medium'; mapped to the matching CVSS band · CWE-1021

Where: `http://juice-shop:3000/socket.io/?EI0=4&transport=polling&t=Q4MmINd&sid=LFm_TPr2aAUWeLalAAAK (2 instance(s))`

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Evidence (from zap): `x-frame-options`

Remediation (from zap): Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Remediation guidance (AI-written): Add the X-Frame-Options header to the response to prevent clickjacking attacks.

[Medium] Content Security Policy (CSP) Header Not Set

ZAP-10038-1 · zap · zap rated it 'medium'; mapped to the matching CVSS band · CWE-693

Where: `http://juice-shop:3000 (54 instance(s))`

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Remediation (from zap): Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Remediation guidance (AI-written): Implement a Content Security Policy (CSP) header to mitigate risks associated with inline scripts and other content.

[Medium] Cross-Domain Misconfiguration

ZAP-10098 · zap · zap rated it 'medium'; mapped to the matching CVSS band · CWE-264

Where: `http://juice-shop:3000/robots.txt (100 instance(s))`

Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

Evidence (from zap): `Access-Control-Allow-Origin: *`

Remediation (from zap): Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance).

Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

Remediation guidance (AI-written): Review and secure the cross-domain configuration to prevent unauthorized access.

[Medium] Session ID in URL Rewrite

ZAP-3-1 · zap · zap rated it 'medium'; mapped to the matching CVSS band · CWE-598

Where: http://juice-shop:3000/socket.io/?EI0=4&transport=polling&t=Q4MmINe&sid=LFm_TPr2aAUWeLaIAAAK (16 instance(s))

URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.

Evidence (from zap): LFm_TPr2aAUWeLaIAAAK

Remediation (from zap): For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.

Remediation guidance (AI-written): Remove or obfuscate the session ID from the URL to prevent session hijacking.

[Low] Retrieved access-control-allow-origin header: *.

NIKTO-000287 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ (1 instance(s))

Retrieved access-control-allow-origin header: *.

Evidence (from nikto): GET /

[Low] /ftp/: This might be interesting.

NIKTO-001675 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ftp/ (1 instance(s))

This might be interesting.

Evidence (from nikto): GET /ftp/

[Low] /public/: This might be interesting.

NIKTO-001811 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/public/ (1 instance(s))

This might be interesting.

Evidence (from nikto): GET /public/

[Low] /.htpasswd: Contains authorization information.

NIKTO-002739 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/.htpasswd (1 instance(s))

Contains authorization information.

Evidence (from nikto): GET /.htpasswd

[Low] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.

NIKTO-002743 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/.bash_history (1 instance(s))

A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.

Evidence (from nikto): GET /.bash_history

[Low] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.

NIKTO-002756 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/.sh_history (1 instance(s))

A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.

Evidence (from nikto): GET /.sh_history

[Low] Suggested security header missing: content-security-policy.

NIKTO-013587 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ (1 instance(s))

Suggested security header missing: content-security-policy.

Evidence (from nikto): GET /

[Low] Uncommon header(s) 'x-recruiting' found, with contents: ##/jobs.

NIKTO-999100 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ (1 instance(s))

Uncommon header(s) 'x-recruiting' found, with contents: ##/jobs.

Evidence (from nikto): GET /

[Low] /robots.txt: contains 1 entry which should be manually viewed.

NIKTO-999996 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/robots.txt (1 instance(s))

contains 1 entry which should be manually viewed.

Evidence (from nikto): GET /robots.txt

[Low] /ftp/: /robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200).

NIKTO-999997 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ftp/ (1 instance(s))

/robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200).

Evidence (from nikto): GET /ftp/

[Low] X-Content-Type-Options Header Missing

ZAP-10021 · zap · zap rated it 'low'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000/socket.io/?EI0=4&transport=polling&t=Q4MmILB (4 instance(s))

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

Evidence (from zap): x-content-type-options

Remediation (from zap): Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

[Low] Timestamp Disclosure - Unix

ZAP-10096 · zap · zap rated it 'low'; mapped to the matching CVSS band · CWE-497

Where: http://juice-shop:3000/sitemap.xml (102 instance(s))

A timestamp was disclosed by the application/web server. - Unix

Evidence (from zap): 1666666667

Remediation (from zap): Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

[Low] Private IP Disclosure

ZAP-2 · zap · zap rated it 'low'; mapped to the matching CVSS band · CWE-497

Where: http://juice-shop:3000/rest/admin/application-configuration (1 instance(s))

A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.

Evidence (from zap): 192.168.99.100:3000

Remediation (from zap): Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.

[Info] Open port 3000/tcp (ppp?)

NMAP-3000-tcp · nmap · open port, reported for information

Where: 172.19.0.4:3000 (1 instance(s))

Port 3000/tcp is open. nmap could not fingerprint the service; 'ppp' is its default guess for this port number.

Evidence (from nmap): 3000/tcp open ppp?

[Info] FingerprintHub Technology Fingerprint (qm-system)

NUCLEI-fingerprinthub-web-fingerprints:qm-system · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-200

Where: http://juice-shop:3000 (1 instance(s))

FingerprintHub Technology Fingerprint tests run in nuclei.

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] HTTP Missing Security Headers (content-security-policy)

NUCLEI-http-missing-security-headers:content-security-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (1 instance(s))

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] HTTP Missing Security Headers (cross-origin-embedder-policy)

NUCLEI-http-missing-security-headers:cross-origin-embedder-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (1 instance(s))

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] HTTP Missing Security Headers (cross-origin-opener-policy)

NUCLEI-http-missing-security-headers:cross-origin-opener-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (1 instance(s))

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] HTTP Missing Security Headers (cross-origin-resource-policy)

NUCLEI-http-missing-security-headers:cross-origin-resource-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (1 instance(s))

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] HTTP Missing Security Headers (permissions-policy)

NUCLEI-http-missing-security-headers:permissions-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (1 instance(s))

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] HTTP Missing Security Headers (referrer-policy)

NUCLEI-http-missing-security-headers:referrer-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (1 instance(s))

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] HTTP Missing Security Headers (strict-transport-security)

NUCLEI-http-missing-security-headers:strict-transport-security · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (1 instance(s))

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] HTTP Missing Security Headers (x-permitted-cross-domain-policies)

NUCLEI-http-missing-security-headers:x-permitted-cross-domain-policies · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (1 instance(s))

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] OWASP Juice Shop

NUCLEI-owasp-juice-shop-detect · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band

Where: http://juice-shop:3000 (1 instance(s))

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] Public Swagger API - Detect

NUCLEI-swagger-api · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-200

Where: http://juice-shop:3000/api-docs/swagger.yaml (1 instance(s))

Public Swagger API was detected.

Evidence (from nuclei): Template matched at http://juice-shop:3000/api-docs/swagger.yaml

[Info] Wappalyzer Technology Detection (google-font-api)

NUCLEI-tech-detect:google-font-api · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band

Where: http://juice-shop:3000 (1 instance(s))

Evidence (from nuclei): Template matched at http://juice-shop:3000

[Info] Modern Web Application

ZAP-10109 · zap · zap rated it 'informational'; mapped to the matching CVSS band

Where: http://juice-shop:3000/sitemap.xml (44 instance(s))

The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.

Evidence (from zap): <script>
window.addEventListener("load", function(){
window.cookieconsent.initialise({
"palette": {
"popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },
"button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" }
},
"theme": "classic",
"position": "bottom-right",
"content": { "messa...

Remediation (from zap): This is an informational alert and so no changes are required.

[Info] Session Management Response Identified

ZAP-10112 · zap · zap rated it 'informational'; mapped to the matching CVSS band

Where: http://juice-shop:3000/rest/continue-code (1 instance(s))

The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

Evidence (from zap): continueCode

Remediation (from zap): This is an informational alert rather than a vulnerability and so there is nothing to fix.